

For this exercise, the hypothetical organization that I will be working with will be called Cyber Medical Inc. Cyber Medical Inc is a mid-sized company that has grown greatly in recent years due to the unique services they offer. They offer cloud services to many hospitals to hold patients' data so that information on patients can be accessed remotely from anywhere in the USA. Due to the pandemic, they grew rapidly and hired many of their new workers remotely, so many coworkers have never met each other in person. They have branches all over the United States of America, as well as storage facilities to host data.

In a world where mostly every important aspect of an individual is digitized, a person's PPI, which includes their medical information, is an extremely valuable commodity. For a long time, a lot of pertinent medical information was simply only kept on hard copy, which for a generation of older doctors who are not tech-savvy can be quite frustrating to understand rules regarding patient data in this new form. Many new types of ransomware attacks to lock hospitals out of their systems in exchange for money have been conducted successfully in the last few years, and the number of attempts is only rising.

The scenario I will be using for this tabletop exercise is a cyber attack against Cyber Medical Inc. The attack will be by a group of hackers who will be attempting to steal social security numbers, health information, any related PPI, or compromising information on individuals using Cyber Medical Inc as their CaaS. After the information is stolen, then the system will have ransomware installed so that only attackers can get into the system. The main participants will be the IT department, Risk management, Cybersecurity team, legal, and day-to-day operations. Additionally, the stakeholders who will, in this case, be the hospitals, are also participants. All roles have been made aware of the necessary information pertaining to their job in the scenario.

In this scenario, we will walk through a threat intelligence report, The Evolution of Ransomware: Victims, Threat Actors, and What to Expect in 2022. In this report, researchers both detail the origins of ransomware as well as the current state we are currently residing in. The attacks over time have only gotten more complex, and due to the value of medical information, threats against hospitals have only increased, especially during times of crisis.

The intelligence report notes that while the median revenue for ransomware victims is around 20 million, all companies are at risk. Data theft or encrypting drives to make them unusable is a key component of ransomware. Since 2016 major ransomware groups such as Locky and Cerber has been shifting their focus and efforts toward healthcare organizations.

Risk 1: A major risk for a hospital would be that during a crisis where every minute counts would be missing information that would be needed to solve the situation. If you could imagine someone bleeding out in the emergency room, they may only have seconds before they need to get a blood transfusion or they perish. If all of a sudden all the hospital records become encrypted, then no way of providing even the most basic care. Hospitals are also geographically located so that everyone in a certain area will be able to receive care, so if one or a nearby network of hospitals goes out simultaneously, then help can be hours out in situations that are touch and go. Multiple backups would greatly reduce the risk of ransomware, but as a new mid-size company trying to expand server space during a time when the USA was having multiple electronic shortages, it would be difficult.

Likelihood: Based on the threat report, the likelihood a company of our size as well as data of size as well would make a great target with a likelihood of being attacked being an 8.

Impact: The impact would be catastrophic because not only would data be lost, but people could die, so the impact would be high if successful, but one backup would reduce the impact greatly. So, the impact would be 8 though a single point of failure just means the attackers have to succeed twice if backups aren't offline.

Risk: $8 \times 8 = 64$ (High)

Remediation: Backups done weekly to prevent loss to access of information.

Risk 2 - Extortion is usually the main goal of a ransomware attack. When it comes to hospitals and medical data, since they are PII, the information can be quite personal and usually extremely private for each individual. Privacy is entangled with trust, and once a company loses the trust of an individual, they are doomed to fail. That is why a shift occurred around 2019 when major players in the ransomware communities began to release or threaten to release compromised information since backups were becoming more prevalent. A patient with cancer, AIDS, or any condition would not want the world to know information that was so intimate to them. Hospitals are in a unique position where a lot of this information is front-facing and accessed by many doctors and nurses daily. This can lead to a false threat where an insider provides certain key details of patients to look as if all the data has been unencrypted and is ready to be released online.

Likelihood: Extortion and insider threats are both threats that combined pose an immense risk to hospitals. The chances of both occurring at the same time in an organization are very high because ransomware attempts are extremely profitable, and many nurses/hospital staff are underpaid and can be bribed potentially to release patient information. They may be unaware that this information will be later used in a ransomware attack as a fake way to show that data isn't in an encrypted form.

Numerically, the likelihood would be a 9.

Impact: Most hospitals are now covered by some type of ransomware insurance under certain situations. In the case of another company, such as Cyber Medical Inc, failing to keep data secure, then liability would most likely fall onto us, but if data was still encrypted when stolen, that could be another issue to bring up. The time it would take to conduct a proper investigation on whether or not data was actually stolen and is now unencrypted is not something hospitals can afford to guess on. The impact would be 9 because even with a little proof, they would have to take the extortion threat seriously.

Risk: $9 \times 9 = 81$ (critical)

Risk 3: Multiple vectors of attacks due to the fact data is being hosted online on a separate server. Hospitals would not only fall under the category of healthcare but business services, which make up 11.5 percent of all ransomware attacks. During Covid, many companies were pushed to their limits due to the fact they had a record number of users and data to host. When using a CaaS, the risk of being targeted as a part of a bigger cyber attack on data being hosted increases. Numerically, it would be 6.

Likelihood: The total likelihood that hospital data would be compromised due to using a CaaS would be approximately 18 percent when you combine both healthcare and business services. Impact: The impact of a compromise would be large, but less than being targeted due to the fact that you would have to show greater proof/burden that all sorts of data have been unencrypted. Numerically, it would be 6.

Risk: $6 \times 6 = 36$ (low) The best way to prevent long-term exposure and risk to hosting medical data is to back up systems regularly and track who has access to all medical information.